OPERAZIONE "IRON RAILS"

Destinatario: Ufficio del Ministro / Autorità Nazionale Cybersecurity
Data: 23 Marzo 2022, ore 16:30 CET
Classificazione: TLP RED **Livello:** 7
Analisi: Strategic CTI
Sggetto: Analisi e Attribuzione dell'attacco ai sistemi Trenitalia/RFI.

1. Sommario Esecutivo (SITREP)

In data odierna, i sistemi di biglietteria e i servizi digitali di Ferrovie dello Stato Italiane sono stati colpiti da un incidente informatico su vasta scala. Sebbene la circolazione ferroviaria rimanga operativa (grazie all'isolamento tempestivo della rete RFI), l'infrastruttura amministrativa e di vendita è gravemente compromessa.
Conclusione Primaria: L'evidenza tecnica indica un attacco di tipo **Ransomware a scopo estorsivo**, condotto da un gruppo criminale organizzato, e **non** un attacco di distruzione di massa (Wiper) di matrice statale russa (GRU/Sandworm).

2. ANALISI TATTICA (TTPs)

Sulla base dei log analizzati sul server V-TKT-04, abbiamo ricostruito la seguente catena d'attacco:

Inibizione del ripristino (T1490): Ore 08:16:12. L'attaccante ha eseguito vssadmin.exe Delete Shadows /All /Quiet. Questo comando elimina i backup locali (Shadow Copies), impedendo il ripristino dei dati senza la chiave di decifratura.

Interruzione dei Servizi (T1489): Ore 08:16:30. Arresto forzato del servizio MSSQLSERVER. Questa manovra è tipica dei ransomware per "sbloccare" i file dei database e permetterne la cifratura completa. <Data Name="param1">SQL Server (MSSQLSERVER)</Data>

Cifratura dei Dati (T1486): Ore 08:17:05. Esecuzione di un binario malevolo (svchost_update.exe) che ha rinominato i file database con estensione **.hive**.
<Data Name="Image">C:\Users\Public\svchost_update.exe</Data>
<Data Name="TargetFilename">C:\DB_Backups\Ticket_Log_2022.sql.hive</Data>

Esfiltrazione (T1041): La nota di riscatto conferma il furto di dati sensibili (Double Extortion) prima della cifratura.

3. ATTORE:

L'attacco è attribuito con **alto grado di confidenza** al gruppo **HIVE RANSOMWARE**.
Indicatori di Compromissione (IoC): L'estensione dei file .hive e l'URL del portale di negoziazione (hive462...onion) sono firme inequivocabili di questo gruppo.

Differenziazione da Sandworm: A differenza degli attacchi russi visti in Ucraina (es. HermeticWiper), questo attacco non mira a distruggere il Master Boot Record (MBR) per rendere i server inutilizzabili, ma a cifrare i file per estorcere denaro. La presenza di una **Ransom Note** e di un canale di comunicazione per il pagamento esclude la finalità di puro sabotaggio geopolitico "Wiper".

4. VALUTAZIONE GEOPOLITICA:

Nonostante l'autore sia un gruppo criminale (Cybercrime) e non un'unità militare (GRU), il contesto resta critico:

Opportunismo Bellico: L'attacco avviene a meno di un mese dall'inizio dell'invasione russa in Ucraina. I gruppi RaaS (Ransomware-as-a-Service) russi o filorussi stanno intensificando i colpi contro infrastrutture critiche dei paesi NATO, sfruttando la distrazione dei team di difesa e cercando di creare instabilità sociale.

Guerra Ibrida "Indiretta": Anche se la motivazione è finanziaria, l'impatto su un asset strategico nazionale (Trasporti) serve gli interessi del Cremlino, alimentando un senso di vulnerabilità nella popolazione civile italiana.

Posizionamento Internazionale: L'Italia è percepita come target prioritario a causa del suo sostegno attivo all'Ucraina e delle sanzioni alla Russia.

5. DIAMOND MODEL DELL'ATTACCO:

DETTAGLIO DELLE COMPONENTI

1. Attaccante: HIVE RANSOMWARE GROUP

Profilo: Gruppo criminale organizzato di tipo RaaS (Ransomware-as-a-Service).

Origine: Operatori di lingua russa (area CIS).

Obiettivo: Estorsione finanziaria. Sebbene l'attacco avvenga durante la crisi Ucraina, non si riscontra la firma di unità militari (es. Sandworm). Tuttavia, il gruppo beneficia della protezione/tolleranza statale russa per colpire obiettivi NATO.

2. CAPABILITY (Capacità): ARSENALE TECNICO

Payload: Binario svchost_update.exe (ransomware personalizzato).

Manipolazione File System: Eliminazione delle copie shadow tramite vssadmin.exe per impedire il ripristino autonomo.

Targeting Database: Arresto forzato del servizio MSSQLSERVER per sbloccare e cifrare i dati dei ticket (.hive).

Doppia estorsione: Capacità di esfiltrare dati sensibili prima della cifratura.

3. INFRASTRUCTURE (Infrastruttura): CANALI DI COMUNICAZIONE:

C2 & Leak Site: Portale live chat e pagamento ospitato sulla rete **TOR** (http://hive462...onion).

Vettore: Sfruttamento di credenziali amministrative (Admin_Svc) su server critici di rete (V-TKT-04.trenitalia.local).

Anonimato: Utilizzo di crittografia asimmetrica e rete Onion per rendere l'infrastruttura di pagamento resiliente ai tentativi di sequestro (Takedown).

4. Obbiettivo: FERROVIE DELLO STATO ITALIANE

Settore: Trasporti e Logistica (Infrastruttura Critica Nazionale).

Asset Compromessi: Database dei biglietti, tablet di bordo (capitreno), sistemi di vendita fisica/self-service.

Impatto: Interruzione dei servizi al cittadino e potenziale fuga di dati finanziari/personali.

RELAZIONI STRATEGICHE

Asse Tecnico (Capability-Infrastructure): L'integrazione tra il malware e il portale TOR conferma una struttura operativa professionale e ben collaudata, tipica del crimine organizzato di alto livello.

Asse Sociale-Politico (Adversary-Victim): L'attacco dimostra come la criminalità informatica possa agire da "moltiplicatore di forza" in un conflitto ibrido: colpendo Trenitalia in un momento di crisi internazionale, Hive ottiene massima visibilità e pressione sulla vittima, servendo indirettamente gli interessi geopolitici della Russia pur mantenendo una "negabilità plausibile".

RACCOMANDAZIONE AL MINISTRO:

Non si tratta di un atto di guerra cibernetica diretta, ma di un attacco criminale ad alto impatto.

Si consiglia di:

1° **Negare il pagamento** del riscatto (linea governativa).

2° Procedere al ripristino tramite backup offline (se non compromessi).

3° Mantenere l'allerta massima: gruppi "hacktivisti" (tipo Killnet) potrebbero lanciare attacchiDDoS nelle prossime ore per cavalcare l'onda del disservizio.